

Agent Handbook — 07 Care Management & Population Health

Stratifies risk and drafts care-plan updates for care managers — with a fairness screen, 42 CFR Part 2 consent, and a **gated care-plan write**. Maturity: Demonstrated + Deployable-by-design; production-readiness (CSV/CSA, IdP, live connectors, pen test, HITRUST) is the engagement; AWS BAA precedes any PHI.

Workflow + human gate

Stratify a population/member by risk → run the **four-fifths fairness screen** on the risk ranking → **check 42 CFR Part 2 consent** before touching sensitive data; escalate if absent → **draft** a care-plan update → **suspend at the Care-Manager gate** for review before any care-plan write. **Named human gate:** Care Manager.

Systems / connectors (with standards)

- **EHR / FHIR** — Epic / Oracle Health via Amazon HealthLake (FHIR R4): conditions, observations, utilization.
- **Consent ledger** — 42 CFR Part 2 / sensitive-scope consent before disclosure.
- **Knowledge base** — care-guideline corpus for grounding.

Workforce roles to map in the IdP

CARE_MANAGER (the gate). Map to custom:hpp_role.

Withheld authority (what it never does)

The care-plan write is gated — the agent drafts; the Care Manager approves before any write. It runs a **risk-stratification fairness screen** and **never discloses or acts on 42 CFR Part 2** data without an explicit consent grant.

Deploy (fixture mode, no PHI)

scripts/build_lambdas.sh

scripts/deploy.sh 07-care-management-pophealth dev portable native s3://my-cfn-staging/hpp 10.36.0.0/16

- Params: infra/cloudformation/params/07-care-management-pophealth.json · Terraform: terraform apply -var-file=envs/07-care-management-pophealth.tfvars
- VPC CIDR 10.36.0.0/16.

Human-gate smoke test

1. Sign in as a seeded CARE_MANAGER.
2. Stratify risk → confirm the **four-fifths fairness screen** ran on the ranking.
3. On a record **without** Part 2 consent → confirm the agent **escalates** rather than disclosing.

4. With consent, draft a care-plan update → run **suspends** at the Care-Manager gate; approve → care-plan write proceeds and is written to the **append-only PHI-masked audit**; reject → no write.

Key regs

HIPAA Privacy/Security, HITECH; **42 CFR Part 2** (SUD/behavioral-health consent); **Section 1557** (nondiscrimination — the fairness screen); **NCQA** population-health/care-management standards.

Go-live checklist

- ☐ AWS BAA + SI BAA executed; no PHI before both.
- ☐ IdP federated; CARE_MANAGER mapped to custom:hpp_role.
- ☐ FHIR connector validated; **42 CFR Part 2 consent ledger** wired to the consent source of truth.
- ☐ **Four-fifths fairness screen** validated on customer data; CSV/CSA signed off; HITL SLA ratified.
- ☐ Pen test + HITRUST/SOC 2 evidence assembled; observability + runbooks adopted.